

MAPEO NORMATIVO QQM + PRAGMATIC

Cada Indicador CIA Triad → Objetivo QQM → Marco Normativo → PRAGMATIC

CIA Triad Metrics Framework — España 2025

*"La norma sin métrica es aspiración. La métrica sin norma es ingeniería sin brújula.
El mapeo que sigue es la brújula con todos los meridianos trazados."*

INSTRUCCIONES DE USO

Esta tabla de referencia cruza los **22 indicadores CIA Triad** con:

- El **Objetivo QQM** de nivel nacional que les da sentido
- La **Pregunta QQM** operacional específica
- El **Marco normativo principal** de referencia
- El **Artículo / Control específico** invocado
- Los **Marcos secundarios** de refuerzo
- El **Score PRAGMATIC** y la **Clase de calidad**
- El **Nivel de obligatoriedad** para España 2025
- El **Plazo de implementación** recomendado

Leyenda de obligatoriedad:

-  **Obligatorio** — Normativa vinculante con régimen sancionador en vigor
-  **Recomendado** — Guía oficial / estándar de referencia sin sanción directa
-  **Emergente** — Normativa en proceso / implementación por fases
-  **Buenas prácticas** — Sin base regulatoria directa; consenso de industria

Leyenda de plazo:

-  **Inmediato** (< 30 días)
-  **Urgente** (30–90 días)
-  **Corto plazo** (3–6 meses)
-  **Medio plazo** (6–18 meses)
-  **Largo plazo** (> 18 meses)

TABLA MAESTRA — PILAR CONFIDENCIALIDAD

ID	Indicador	Objetivo GQM	Pregunta GQM Principal	Marco Principal	Artículo / Control	Marcos Secundarios	PRAGMATIC Score	Clase	Obligatoriedad	Plazo
C-01a	MFA Coverage Rate (%)	OBJ-NAC-01: Proteger credenciales de acceso en sistemas de información	¿Qué % de cuentas tiene MFA habilitado?	NIS2 (UE 2022/2555)	Art. 21(2) (i) — autenticación multifactor	ENS Op.acc. 5; NIST SP 800-63B AAL2; ISO 27001 A.8.5; FIDO Alliance FIDO2	25/27	A	 Obligatorio	 Inmediato
C-01b	Phishing-Resistant MFA Rate (%)	OBJ-NAC-01	¿Qué % de MFAs resiste al phishing (FIDO 2)?	NIST SP 800-63B	AAL3 (phishing-resistant)	CISA MFA Guidance 2025; ENS nivel Alto; FIDO2 /Web Authn	25/27	A	 Recomendado	 Urgente
C-01c	MFA Bypass Attempt Rate (%)	OBJ-NAC-01	¿Cuál es la tasa de intentos de bypass de MFA?	NIST SP 800-53 R5	IA-2(12) — Identification and Authentication	SIEM correlation rules; ENS Op.mon.3	25/27	A	 Recomendado	 Corto plazo

C-02a	Orphan Account Rate (%)	OBJ-NAC-01: Gestión de identidades y mínimo privilegio	¿Qué % de cuentas son huérfanas (ex-empleados activos)?	ISO 27001: 2022	A.5.18 — Derechos de acceso	ENS Op.acc. 4; NIST SP 800-53 AC-2; NIS2 Art. 21(2) (i)	22/27	B	 Obligatorio (ENS)	 Inmediato
C-02b	Access Review Frequency Score	OBJ-NAC-01	¿Con qué frecuencia se revisan privilegios en sistemas críticos?	ISO 27001: 2022	A.5.18 — Revisión de derechos	ENS Op.acc. 4; NIST SP 800-53 AC-2(7); SOC 2 CC6.2	22/27	B	 Obligatorio	 Urgente
C-02c	PAM Coverage Rate (%)	OBJ-NAC-01	¿Qué % de cuentas administradas en PAM con grabación?	NIST SP 800-53 R5	AC-2(7) — Privileged Accounts	CIS Control 15; DORA Art. 9(2); ENS Op.acc. 7	22/27	B	 Recomendado	 Urgente
C-02d	Least Privilege Score (%)	OBJ-NAC-01	¿Qué % de usuarios tienen verificado el mínimo privilegio?	ISO 27001: 2022	A.5.15 — Control de acceso	ENS Op.acc. 6; NIST SP 800-53 AC-6; NIS2 Art. 21(2) (i)	22/27	B	 Obligatorio (ENS Alto)	 Corto plazo

C-03a	Encryption at Rest Coverage (%)	OBJ-NAC-01: Cifrar datos sensibles en reposo	¿Qué % de repositorios de datos sensibles están cifrados?	RGPD (UE 2016/679)	Art. 32(1) (a) — medidas técnicas	ISO 27001 A.8.24; ENS Mp.si. 2; CCN-STIC-807	20/27	B	 Obligatorio (RGPD)	 Inmediato
C-03b	Cryptographic Algorithm Compliance (%)	OBJ-NAC-01	¿Se usan solo algoritmos de cifrado aprobados (AES-256+)?	ENS CCN-STIC-807	Algoritmos aprobados para ENS	NIST SP 800-175B; FIPS 197 (AES-256); ISO 27001 A.8.24	20/27	B	 Obligatorio (ENS)	 Inmediato
C-03c	KMS Separation Score (0/1)	OBJ-NAC-01	¿Las claves están separadas de los datos que cifran?	NIST SP 800-57 Pt.1	\$6.2.2 — Key separation	ISO 27001 A.8.24; NIST SP 800-53 SC-12; ENS Mp.si. 2	20/27	B	 Recomendado	 Urgente
C-04a	Cryptocurrency Completeness (%)	OBJ-NAC-06: Preparar transición post-cuántica	¿Qué % de sistemas tienen algoritmos criptográficos inventariados?	NIST FIPS 203/204/205	Prerequisito migración PQC	NSA CNSA 2.0; ENS CCN-STIC-807 (en revisión PQC)	19/27	B	 Emergente	 Corto plazo

C-04b	Quantum-Vulnerable Exposure Rate (%)	OBJ-NAC-06	¿Qué % de sistemas críticos usan RSA/ECC sin plan de migración?	NIST SP 800-131A Rev.2	Depreciación RSA/ECC timeline	FIPS 203 (ML-KEM); FIPS 204 (ML-DSA); NSA CNSA 2.0	19/27	B	 Emergente	 Medio plazo
C-04c	PQC Migration Progress Score (0-4)	OBJ-NAC-06	¿En qué etapa del roadmap PQC está la organización?	NIST PQC Standards	FIPS 203, 204, 205 (ago 2024)	NSA CNSA 2.0 Timeline; ENISA PQC Guidelines	19/27	B	 Emergente	 Largo plazo
C-05a	DLP Coverage Rate (%)	OBJ-NAC-01 / OBJ-NAC-05	¿Qué % del tráfico de salida está analizado por DLP?	RGPD (UE 2016/679)	Art. 25 — privacidad por diseño	ISO 27001 A.5.12-5.13; ENS Mp.info.3; NIS2 Art. 21	22/27	B	 Recomendado	 Corto plazo
C-05b	DLP Block Rate (%)	OBJ-NAC-01	¿Cuántos eventos DLP son bloqueados vs. solo monitorizados?	RGPD Art. 32	Medidas técnicas de protección	ISO 27001 A.5.12; NIST SP 800-53 SI-12	22/27	B	 Recomendado	 Corto plazo

C-05c	DLP False Positive Rate (%)	OBJ-NAC-01	¿Cuál es la tasa de falsos positivos del sistema DLP?	ISO 27001: 2022	A.5.12 — Control calidad	NIST SP 800-53 IR-5; ENS Op.exp .6	22/27	B	 Buena s prácticas	 17 Corto plazo
C-06a	Shadow AI Inventory Rate (%)	OBJ-NAC-05: Gobernanza IA no supervisada	¿Qué % de herramientas IA en uso están inventariadas?	EU AI Act (UE 2024/1689)	Art. 28 — Obligaciones desplegadas	RGPD Art. 25; ISO/IEC 42001: 2023; ENS (en actualización)	19/27	B	 Emergente (AI Act 2025-26)	 17 Corto plazo
C-06b	AI Governance Policy Maturity (0-5)	OBJ-NAC-05	¿Existe política formal de uso de IA generativa?	EU AI Act Art. 9	Sistemas IA alto riesgo — gestión	RGPD Art. 5(limitación propósito); ISO/IEC 42001; NIST AI RMF	19/27	B	 Emergente	 17 Corto plazo
C-06c	Unauthorized AI Use Detection	OBJ-NAC-05	¿Cuántas instancias de Shadow AI se detectan en auditoría?	RGPD Art. 5	Principios tratamiento datos	EU AI Act; ISO/IEC 42001; ENS	19/27	B	 Emergente	 17 Medio plazo

TABLA MAESTRA — PILAR INTEGRIDAD

ID	Indica dor	Objeti vo GQM	Pregu nta GQM Princip al	Marco Princip al	Artícu lo / Contro l	Marco s Secun darios	PRAG MATIC Score	Clase	Obliga toried ad	Plazo
I-01a	FIM Covera ge Rate (%)	OBJ- NAC- 02: Detect ar modifi cacion es no autori zadas	¿Qué % de sistem as crítico s tienen FIM activo?	NIST SP 800-53 R5	SI-7 — Softwa re, Firmw are, and Infor matio n Integri ty	PCI- DSS v4.0 Req. 11.5; ENS Mp.sw .2; ISO 27001 A.8.8	25/27	A	 Obliga torio (PCI/E NS Alto)	 Urgent e
I-01b	FIM Detecti on Time (min)	OBJ- NAC- 02	¿Cuál es el tiempo de detecci ón de modifi cación no autori zada?	ISO 27035	\$6.3 — Incide nt detecti on	NIST CSF 2.0 DE.AE; ENS Op.exp .7; NIST SP 800-53 SI-7(2)	25/27	A	 Recom endad o	 Corto plazo
I-01c	FIM- SIEM Integr ation Score (0/1)	OBJ- NAC- 02	¿Están los alertas FIM integr ados en SIEM con playbo ok?	NIST SP 800-53 R5	SI-7(7) — Integr ation with Detecti on	NIS2 Art. 21(2) (a); ENS Op.mo n.3; DORA Art. 10	25/27	A	 Recom endad o	 Corto plazo

I-02a	TMPV C — Crítica s (días)	OBJ- NAC- 02: Reducir ventana de exposición a CVEs	¿Días entre publicación CVE crítico (CVSS ≥9) y parcheo?	NIS2 (UE 2022/ 2555)	Art. 21(2) (b) — gestión de vulnerabilidades	ENS Op.exp .4; DORA Art. 9(3); NIST SP 800-53 RA-5; CVSS v4.0	26/27	A ★	● Obligatorio	⚡ Inmediato
I-02b	TMPV A — Altas (días)	OBJ- NAC- 02	¿Días entre publicación CVE alto (CVSS ≥7) y parcheo?	NIS2 Art. 21(2) (b)	Gestión de vulnerabilidades	ENS Op.exp .4; ISO 27001 A.8.8; NIST SP 800-53 RA-5	26/27	A ★	● Obligatorio	🔥 Urgente
I-02c	Unpatched Critical Vulnerability Age	OBJ- NAC- 02	¿Número de CVE críticos sin parcheo con > 30 días?	CISA KEV	Known Exploited Vulnerabilities Catalog	ENS Op.exp .4; NIS2 Art. 21; NIST SP 800-53 RA-5(5)	26/27	A ★	● Obligatorio	⚡ Inmediato
I-02d	EPSS- Prioritized Patch Rate (%)	OBJ- NAC- 02	¿% de CVE con EPSS> 0,5 parcheados en ≤7 días?	CISA KEV + EPSS	Exploited activa — priorización	NIS2 Art. 21(2) (b); NIST SP 800-53 RA-5(2)	26/27	A ★	● Recomendado	🔥 Urgente

I-03a	SBOM Cov erage Rate (%)	OBJ- NAC- 02: In tegridad de compo nentes softwa re	¿% aplicac iones en produc ción con SBOM actuali zado?	EU Cyber Resilie nce Act	Art. 13(5) — Softwa re Bill of Materi als	NIST SP 800- 218 (SSDF) ; NIS2 Art. 21(2) (d); Cyclon eDX/S PDX	20/27	B	 Emerg ente (CRA 2027)	 Medio plazo
I-03b	Softwa re Artifac t Verific ation Rate (%)	OBJ- NAC- 02	¿% artefac tos SW verific ados criptog ráfica mente en CI/CD ?	NIST SP 800- 218	PW.4.1 — Softwa re integri ty	EU CRA Art. 13; NIS2 Art. 21(2) (d); SLSA Frame work v1.0	20/27	B	 Recom endad o	 Corto plazo
I-03c	Third- Party Breach Rate (ratio)	OBJ- NAC- 02	¿% incide ntes origin ados en tercer os provee dores?	NIS2 (UE 2022/ 2555)	Art. 21(2) (d) — supply chain securit y	DORA Art. 28; ISO 27001 A.5.19- 5.22; NIST SP 800- 161r1	20/27	B	 Obliga torio (NIS2)	 Corto plazo

I-04a	Digital Signature Coverage (%)	OBJ- NAC- 04: Autent icidad e irrefut abilidad de transa cciones	¿% transa cciones críticas firmadas digital mente con certific ado cualifi cado?	eIDAS 2 (UE 2024/1 183)	Art. 3 QES — Qualified Electronic Signature	DORA Art. 9; ENS Dimensión Autent icidad; ISO 27001 A.8.24	26/27	A ★	● Obliga torio (eIDAS sector)	🔥 Urgent e
I-04b	PKI Health Score (%)	OBJ- NAC- 04	¿% certific ados válidos y no expira dos en uso?	eIDAS 2	Art. 24 — TSP requirements	NIST SP 800- 57; ISO/IE C 27001 A.8.24; RFC 9549 (OCSP)	26/27	A ★	● Obliga torio	⚡ Inmed iato
I-04c	Certifi cate Expiry Advance Notice (días)	OBJ- NAC- 04	¿Días de antela ción en renova ción de certific ados?	ISO 27001: 2022	A.8.24 — Use of crypto graphy	PKI best practice; CAB Forum ; Certifi cate Trans parenc y CT Logs	26/27	A ★	● Recom endado	🔥 Urgent e

I-05a	Log Centralization Rate (%)	OBJ-NAC-02: Trazabilidad e integridad de registros	¿% sistemas críticos con logs en SIEM centralizado?	NIS2 (UE 2022/2555)	Art. 21(2) (f) — logging	DORA Art. 13(7); ENS Op.exp .10; NIST SP 800-53 AU-2; ISO 27001 A.8.15	22/27	B	 Obligatorio	 Urgente
I-05b	Log Retention Compliance (%)	OBJ-NAC-02	¿% sistemas regulados con retención de logs ≥ 12 meses?	ENS RD 311/2022	Op.exp .10 — Protección de los registros (2 años nivel Alto)	NIS2 Art. 21; DORA Art. 13(7); RGPD Art. 5(1)(e)	22/27	B	 Obligatorio (ENS)	 Urgente
I-05c	Log Integrity Verification Rate (ratio)	OBJ-NAC-02	¿Las verificaciones de integridad de logs se realizan según programa?	NIST SP 800-53 R5	AU-9 — Protection of Audit Information	ISO 27001 A.8.15; ENS Op.exp .10; DORA Art. 13(7)	22/27	B	 Recomendado	 Corto plazo

TABLA MAESTRA — PILAR DISPONIBILIDAD

ID	Indica dor	Objeti vo GQM	Pregu nta GQM Princip al	Marco Princip al	Artícu lo / Contro l	Marco s Secun darios	PRAG MATIC Score	Clase	Obliga toried ad	Plazo
A-01a	MTTD — días	OBJ- NAC- 03: Minim izar ventan a de exposi ción	¿Días medio s entre inicio de incide nte y su detecci ón?	NIST CSF 2.0	DE.CM — Contin uous Monit oring	ISO 27035; ENS Op.mo n.1-3; NIS2 Art. 21(2) (a); IBM CODB 2025 ref.	24/27	A	 Recom endad o	 Corto plazo
A-01b	Autom ated Detecti on Rate (%)	OBJ- NAC- 03	¿% incide ntes detect ados por contro les autom áticos vs. notific ación huma na?	NIST CSF 2.0	DE.AE — Anom alies and Events	NIS2 Art. 21(2) (e); ENS Op.mo n.2; DORA Art. 10	24/27	A	 Recom endad o	 Corto plazo
A-01c	SOC Covera ge Hours (%)	OBJ- NAC- 03	¿Qué % del tiempo seman al hay cobert ura SOC activa?	NIS2 (UE 2022/ 2555)	Art. 21(2) (a) — incide nt handli ng	DORA Art. 10; ENS Op.mo n.1; CCN- STIC- 817	24/27	A	 Obliga torio (esenc iales)	 Medio plazo

A-02a	MTTR — horas	OBJ- NAC- 03: Minimizar impacto y duración de incidentes	¿Horas medias entre detección y resolución de incidente crítico?	ISO 27035	\$6.4 — Incident Response	NIST CSF 2.0 RS.CO; DORA Art. 17; NIS2 Art. 21(2) (e)	26/27	A ★	● Obligatorio	⚡ Inmediato
A-02b	MTTC — horas	OBJ- NAC- 03	¿Horas medias entre detección y contención del incidente?	NIST CSF 2.0	RS.CO-3 — Response and Recovery	DORA Art. 17; ISO 27035; ENS Op.exp .7	26/27	A ★	● Recomendado	🔥 Urgente
A-02c	Regulatory Notification Compliance (%)	OBJ- NAC- 03	¿% incidentes notificados en plazo (24h alerta / 72h notificación NIS2)?	NIS2 Art. 23	Notification obligations — 24h/72h	DORA Art. 19; RGD Art. 33 (72h); ENS / CCN-CERT	26/27	A ★	● Obligatorio — Sanción directa	⚡ Inmediato
A-02d	IR Playbook Coverage (%)	OBJ- NAC- 03	¿% tipologías de incidente con playbook probado?	ISO 27035	\$5 — Incident planning	NIS2 Art. 21(2) (e); NIST SP 800-61r3; DORA Art. 11	26/27	A ★	● Recomendado	📅 Corto plazo

A-03a	RTO Definit ion Covera ge (%)	OBJ- NAC- 03: Garant izar recupe ración dentro de umbra les defini dos	¿% sistem as crítico s con RTO defini do formal mente ?	DORA (UE 2022/ 2554)	Art. 12(1) (a) — Recove ry time	ISO 22301: 2019 §6.2; ENS Op.con t.1; NIS2 Art. 21(2) (c)	24/27	A	 Obliga torio (DORA)	 Urgent e
A-03b	RTO Test Compli ance Rate (%)	OBJ- NAC- 03	¿% sistem as que alcanz an RTO en última prueb a?	ISO 22301: 2019	§8.5 — Incide nt respon se proced ures	DORA Art. 11(6) — testing ; ENS Op.con t.2	24/27	A	 Obliga torio (DORA)	 Corto plazo
A-03c	RPO Test Compli ance Rate (%)	OBJ- NAC- 03	¿% sistem as que alcanz an RPO en última prueb a?	ISO 22301: 2019	§6.2 — Recove ry point	DORA Art. 12(1) (b); ENS Mp.inf o.9; NIST SP 800-34	24/27	A	 Obliga torio (DORA)	 Corto plazo
A-03d	BCP Test Freque ncy Score (ratio)	OBJ- NAC- 03	¿Ratio ejercic ios BCP/D RP realiza dos vs. planifi cados?	DORA Art. 11(6)	TLPT / Threat -led testing	ISO 22301 §8.5; ENS Op.con t.3; NIST SP 800-34	24/27	A	 Obliga torio (DORA anual)	 Corto plazo

A-04a	Service Availability Rate (%)	OBJ-NAC-03: Mantener disponibilidad continua de servicios críticos	¿Uptime efectivo de servicios críticos en el periodo?	DORA (UE 2022/2554)	Art. 8(6) — Continuity requirements	SOC 2 CC Availability; ISO 27001 A.8.14; ENS Dimensión Disponibilidad	26/27	A ★	● Obligatorio (DORA)	⚡ Inmediato (monitorización)
A-04b	Unplanned Downtime Hours	OBJ-NAC-03	¿Horas totales de inactividad no planificada en 12 meses?	ISO 27001: 2022	A.8.14 — Redundancy	DORA Art. 8(6); ENS; SLA corporativos	26/27	A ★	● Recomendado	⚡ Inmediato
A-04c	SLA Compliance Rate (%)	OBJ-NAC-03	¿% periodos con SLA de disponibilidad cumplido?	ISO 27001: 2022	A.8.14; contractual obligations	DORA Art. 8; SOC 2	26/27	A ★	● Recomendado	⚡ Inmediato
A-05a	Backup Verification Rate (%)	OBJ-NAC-03: Resiliencia frente a ransomware	¿% backups con verificación de restauración exitosa?	ISO 27001: 2022	A.8.13 — Información backup	DORA Art. 12; ENS Mp.info.9; NIST SP 800-34	23/27	B	● Obligatorio	🔥 Urgente

A-05b	Backup Isolation Score (0-3)	OBJ-NAC-03	¿Nivel de aislamiento de backups respecto a red de producción?	NIST SP 800-34 Rev.1	\$3.5 — Backup strategies	ENS Mp.info.9; ISO 22301; CISA Ransomware Guide	23/27	B	 Recomendado	 Urgente
A-05c	Ransomware Recovery Exercise Completion (%)	OBJ-NAC-03	¿% ejercicios de recuperación ransomware completados vs. planificados?	ISO 22301: 2019	\$8.5 — Exercising	INCIBE Ransomware Response; No More Ransom; DORA Art. 11	23/27	B	 Recomendado	 Corto plazo
A-05d	Time to Recover vs. RTO (ratio)	OBJ-NAC-03	¿Ratio tiempo real de recuperación en simulacro vs. RTO definido?	ISO 22301	\$8.5 + \$6.2	DORA Art. 12; ENS Op.con t.2-3	23/27	B	 Recomendado	 Corto plazo

A-06a	Edge Device Patch Latency (días)	OBJ-NAC-02/03: Reducir exposición por borde de red	¿Días entre publicación CVE borde y parcheo en prod?	CISA KEV	Known Exploited Vulnerabilities	ENS Op.exp .4; NIS2 Art. 21(2) (b); Verizón DBIR 2025 (8× vector borde)	25/27	A	 Obligatorio (NIS2)	 Inmediato
A-06b	Edge Device Inventory Completeness (%)	OBJ-NAC-02/03	¿% dispositivos de borde en inventario actualizado?	NIS2 Art. 21(2) (b)	Asset management	ENS Op.pl.1 ; NIST SP 800-53 CM-8; ISO 27001 A.5.9	25/27	A	 Obligatorio (NIS2)	 Urgente
A-06c	CISA KEV Monitoring Coverage (%)	OBJ-NAC-02/03	¿% dispositivos borde con KEV monitorizados activamente?	CISA KEV Catalog	Binding Operational Directive 22-01	ENS Op.exp .4; NIS2 Art. 21(2) (b)	25/27	A	 Recomendado	 Urgente

TABLA MAESTRA — EXTENSIONES CIANA (AUTENTICIDAD Y TRAZABILIDAD)

ID	Indica dor	Objeti vo GQM	Pregu nta GQM Princip al	Marco Princip al	Artícu lo / Contro l	Marco s Secun darios	PRAG MATIC Score	Clase	Obliga toried ad	Plazo
AT-01a	Privileged Session Recording Rate (%)	OBJ-NAC-04: Trazabilidad de acciones privilegiadas	¿% sesiones privilegiadas grabadas íntegramente?	ENS RD 311/2022	Dimensión Trazabilidad	DORA Art. 13(7); NIS2 Art. 21(2) (f); PAM best practice; ISO 27001 A.8.15	24/27	A	 Obligatorio (ENS Alto)	 Urgente
AT-01b	Session Record Integrity Score (0/1)	OBJ-NAC-04	¿Los registros de sesión son inmutables y con acceso separado?	NIST SP 800-53 R5	AU-9 — Protection of Audit Information	ENS Op.exp .10; DORA Art. 13(7); ISO 27001 A.8.15	24/27	A	 Obligatorio (ENS)	 Corto plazo
AT-02a	Security Training Completion Rate (%)	OBJ-NAC-01-06 (transversal): Cultura de seguridad	¿% empleados con formación de ciberseguridad completada?	NIS2 Art. 20(2)	Formación de órganos directivos	ENS Org.2; ISO 27001 A.6.3; NIST SP 800-50	24/27	A	 Obligatorio (NIS2 directivos)	 Urgente

AT-02b	Phishing Simulation Click Rate (%)	Transversal	¿Tasa de clics en simulacros de phishing?	NIST SP 800-50	Awareness and Training	ENISA Awareness Guidelines; ENS Org.3; Know Be4/P roofpo int	24/27	A	 Recomendado	 Corto plazo
AT-02c	Incident Reporting Rate (%)	Transversal	¿% incidentes reportados activamente por empleados?	ISO 27001: 2022	A.6.8 — Reporting	ENS Org.3; NIS2 Art. 20; NIST SP 800-50	24/27	A	 Recomendado	 Corto plazo
AT-02d	Executive Security and Training Compliance (%)	Transversal	¿% directivos con formación de ciberseguridad completada (NIS2)?	NIS2 Art. 20(2)	Formación obligatoria directivos	ENS; CCN-STIC; ISACA Board Cyber Briefings	24/27	A	 Obligatorio (NIS2)	 Urgente
AT-03a	ZT Maturity Level (CISA 0-3)	OBJ-NAC-01-03 (transversal): Arquitectura Zero Trust	¿En qué nivel del modelo CISA ZT Maturity se encuentra la org.?	NIST SP 1800-35	Zero Trust Architecture (jun 2025)	CISA ZTA Maturity Model v2; ENS (en revisión ZT); DORA	17/27	C	 Buenas prácticas	 Medio plazo

AT-03b	Network Microsegmentation Coverage (%)	OBJ-NAC-01-03	¿% segmentos de red críticos con microsegmentación?	NIST SP 800-53 R5	SC-7 — Boundary Protection	CISA ZTA; ENS Nivel Alto; NIS2 Art. 21(2)	17/27	C	 Recomendado	 Medio plazo
AT-03c	Continuous Authentication Coverage (%)	OBJ-NAC-01	¿% usuarios en acceso a activos críticos con autenticación continua?	NIST SP 1800-35	ZTA — Continuous Verification	CISA ZTA; ENS Op.acc. 5; NIS2 Art. 21(2) (i)	17/27	C	 Buenas prácticas	 Largo plazo

RESUMEN EJECUTIVO: COBERTURA NORMATIVA POR MARCO

Marco Normativo	Indicadores Cubiertos	Pilares	Tipo Obligatoriedad	Sanciones Máximas
ENS (RD 311/2022)	C-01, C-02, C-03, I-01, I-04, I-05, A-01, A-03, A-04, A-05, AT-01	C + I + A + Auth + Traz	● AAPP + proveedores	Administrativa
NIS2 (UE 2022/2555)	C-01, C-02, I-02, I-03, I-05, A-01, A-02, A-03, A-06, AT-01, AT-02	C + I + A + Traz	● Esenciales: 10M€ / 2% facturación	Hasta 10M€
DORA (UE 2022/2554)	C-02, I-04, I-05, A-02, A-03, A-04, A-05, AT-01	A (principal) + C + I	● Sector financiero	Según BDE/CNMV
RGPD (UE 2016/679)	C-03, C-05, C-06, I-05, A-02	C (principal)	● Universal	Hasta 20M€ / 4% facturación
ISO 27001:2022	Todos (referencia cruzada)	C + I + A	● Certificación voluntaria	—
NIST CSF 2.0	C-01, I-01, I-02, A-01, A-02, AT-03	C + I + A	● Referencia internacional	—
NIST PQC (FIPS 203-205)	C-03, C-04, I-04	C + I	● Estándar publicado ago 2024	—
EU AI Act (UE 2024/1689)	C-06, I-05 (IA)	C + I	● Por fases 2025-2027	Hasta 35M€ / 7% facturación
eIDAS 2 (UE 2024/1183)	I-04, AT-01	Auth + I	● Sectores eIDAS	Según supervisor
EU CRA	I-03	I	● Aplicación 2027	Hasta 15M€ / 2,5% facturación
CISA KEV	I-02, A-06	I + A	● BOD 22-01 (USA) / Referencia ES	—

PRIORIZACIÓN INTEGRADA GQM+PRAGMATIC+NORMATIVA

Nivel de Urgencia ROJO — Acción Inmediata (< 30 días)

Indicador	Razón de Urgencia
M-I02a (TMPVC Críticas)	CVE CVSS≥9.0 activos sin parche = riesgo de explotación en horas
M-A04a (Uptime)	Si no se monitoriza, el incidente ya está ocurriendo sin detección
M-A02c (Notificación regulatoria)	Incumplimiento NIS2/DORA tiene sanción directa e inmediata
M-C01a (MFA Coverage)	Vector #1 de brecha; cada cuenta sin MFA es una puerta abierta
M-I04b (PKI Health)	Certificado expirado = servicio caído o advertencia de seguridad para usuarios
M-I02c (CVE > 30 días)	Umbral de explotación masiva documentado por CISA y Verizon
M-A06a (Edge Patch Latency)	8× incremento vector borde; exposición activa según CISA KEV

Nivel de Urgencia NARANJA — Urgente (30-90 días)

Indicador	Razón de Urgencia
M-C02a (Orphan Accounts)	Riesgo de acceso post-baja; auditoría ENS inminente
M-C02b (Access Review)	NIS2 exige gestión formal; auditoría NIS2 en 2026
M-C03b (Algoritmos Legacy)	3DES/SHA-1/MD5 = deuda técnica con riesgo regulatorio creciente
M-I01a (FIM Coverage)	PCI-DSS y ENS Alto; gap de detección de modificaciones
M-A05a (Backup Verification)	Ransomware sin backups verificados = desastre total
M-A05b (Backup Isolation)	Backups conectados = backups cifrados en ataque ransomware
M-AT02a (Training NIS2)	NIS2 Art. 20(2) exige formación de directivos; obligación vigente
M-AT02d (Executive Training)	Responsabilidad personal directivos bajo NIS2
M-I05a (Log Centralization)	Prerequisito de capacidad forense y cumplimiento NIS2/DORA
M-AT01a (Session Recording)	ENS nivel Alto; prerequisite investigación forense

Mapeo Normativo GQM+PRAGMATIC CIA Triad v2025 · Referencias: ENS RD 311/2022, NIS2 (UE 2022/2555), DORA (UE 2022/2554), RGPD (UE 2016/679), EU AI Act (UE 2024/1689), eIDAS 2 (UE 2024/1183), EU CRA (en tramitación), NIST CSF 2.0, NIST SP 800-53 R5, NIST PQC FIPS 203/204/205, CISA KEV, ISO/IEC 27001:2022, ISO 22301:2019